LAPORAN VERIFIKASI KEAMANAN MENDALAM

FASE 2A — DEEP VERIFICATION OF CRITICAL & HIGH SECURITY FINDINGS

Aplikasi: **Mini ERP Keylock Indonesia** (Laravel 12 & PostgreSQL)

PT KEYLOCK INDONESIA

TARGET STACK	TARGET DEPLOYMENT	AUDITOR ROLE	METODE AUDIT
Laravel 12 & PostgreSQL	Shared Hosting / cPanel	Sr. Architect & Sec Auditor	Fase 2A (Strict Read-Only)

SEC-01	SEC-02	SEC-03	SEC-04	SEC-05	SEC-06
CONFIRMED	CONFIRMED	CONFIRMED	CONFIRMED	POTENTIAL	VERIFIED OK
Base64 Upload RCE	Admin Route Auth	Filament Open Access	IDOR Mutation Orders	IDOR Document Read	CRM Lead Auth

1 VERIFIKASI FILE UPLOAD QUOTATION (BASE64 TO STORAGE)

TEMUAN SEC-01: Arbitrary File Upload via Base64 Berpotensi RCE

CRITICAL CONFIRMED

`Berkas: app/Http/Controllers/Erp/ErpController.php (L1046, L1147-1164 di storeQuotation & L1245, L1330-1346 di updateQuotation)`

A. Jalur Eksekusi Lengkap:

1. **Asal Data:** Di client-side modal penawaran (`resources/views/layouts/erp.blade.php` L974-984), Alpine.js membaca file dengan `FileReader.readAsDataURL(file)` dan mengirim string base64 pada field `items.*.image`.
2. **Aturan Validasi:** Pada `ErpController.php` L1046 & L1245, field hanya divalidasi dengan: `'items.*.image' => 'nullable|string'`. Tidak ada rule mimes, image, dimensions, atau max size.
3. **Ekstraksi Ekstensi Mentah:** Controller memeriksa `str_starts_with($imagePath, 'data:image/')` lalu mengekstrak ekstensi langsung:

```
if (preg_match('/image\/([a-zA-Z0-9]+)/', $type, $m)) {
    $ext = $m[1]; // Ekstensi diambil mentah tanpa validasi whitelist
}
$filename = 'quotation_items/' . uniqid('unit_') . '.' . $ext;
\Illuminate\Support\Facades\Storage::disk('public')->put($filename, $decoded);
$imagePath = 'storage/' . $filename;
```

4. **Penyimpanan Publik:** Berkas ditulis ke disk `public` (`storage/app/public/quotation_items/unit_xxxx.<ext>`) yang terhubung ke web via symlink `public/storage`.
5. **Kebocoran Path Langsung:** Jika request menyertakan `Accept: application/json`, response mengembalikan order lengkap termasuk URL berkas: `'image' => 'storage/quotation_items/unit_xxxx.<ext>'`.

B. Kontrol Keamanan yang Ditemukan:

- Terdapat blok `try-catch (\Throwable $e)` yang menyetel `$imagePath = null` jika decode gagal.
- Nama file diawali prefix acak `uniqid('unit_')` sehingga tidak terjadi tabrakan nama file.

C. Celah & Kelemahan yang Dibuktikan:

Eksekusi PHP di Web Server: Regex `/image\/([a-zA-Z0-9]+)/` mencocokkan payload seperti `...` sehingga ekstensi berkas menjadi `.php`. Karena folder `public/storage` tidak memiliki proteksi `.htaccess` (untuk mematikan engine PHP), server Apache/LiteSpeed di cPanel akan langsung mengeksekusi berkas tersebut ketika diakses via URL, menghasilkan **Remote Code Execution (RCE)**.

D. Perbaikan Minimum yang Direkomendasikan:

- Validasi MIME biner nyata menggunakan `finfo_buffer(finfo_open(FILEINFO_MIME_TYPE), $decoded)`.
- Terapkan whitelist ekstensi ketat: hanya izinkan `jpg`, `jpeg`, `png`, `webp`. Tolak ekstensi lainnya.
- Tambahkan berkas `storage/app/public/.htaccess` yang memblokir eksekusi skrip PHP di folder storage.

E. Rencana Pengujian (Test Case):

Feature test: kirimkan request quotation dengan image base64 ber-header `data:image/php;base64`. Assert sistem melempar validation error 422 dan tidak ada file berekstensi `.php` yang terbentuk di disk.

2 VERIFIKASI AUTHORIZATION & ROLE CHECK

TEMUAN SEC-02: Ketiadaan Middleware Otorisasi & Role Check pada Endpoint Administratif

CRITICAL CONFIRMED

`Berkas: routes/web.php (L36-163), bootstrap/app.php (L16), ErpController.php (L548-850), ConfigController.php (L11-220)`

A. Jalur Eksekusi Lengkap:

1. Middleware `CheckRole::class` dialias sebagai `'role'` di `bootstrap/app.php` L16.
2. Di `routes/web.php` L36, grup prefix `/erp` **hanya dilindungi oleh middleware `auth`**:

```
Route::middleware(['auth'])->group(function () {
    Route::prefix('erp')->name('erp.')->group(function () {
        Route::get('/users', [ErpController::class, 'userManagement'])->name('users.index');
        Route::post('/users', [ErpController::class, 'storeUser'])->name('users.store');
        Route::post('/users/{id}/update', [ErpController::class, 'updateUser'])->name('users.update');
        Route::post('/roles', [ErpController::class, 'storeRole'])->name('roles.store');
        Route::post('/system-menus', [ErpController::class, 'systemMenus'])->name('menus.index');
        Route::post('/system-configs/company', [ConfigController::class, 'updateCompany'])-
>name('configs.company.update');
    });
});
```

3. Di sisi controller (`ErpController.php` dan `ConfigController.php`), **tidak ada pengecekan `$this->authorize()`, `Gate::allows()`, maupun verifikasi `isAdmin()`**.

B. Kontrol Keamanan yang Ditemukan vs Celah:

- **Filter Sidebar (UI Only):** `AppMenu::getTreeForUser` di `AppServiceProvider` menyembunyikan link "User Management" dari sidebar staf non-admin. Namun ini **bukan kontrol keamanan server**.
- **Self-Toggle Prevention:** Pada `toggleUserStatus` L656 ada proteksi `if (auth()->id() == $user->id) return 400;`, namun staf non-admin tetap dapat menonaktifkan akun Superadmin.

C. Pembuktian Privilege Escalation:

> Setiap pengguna yang berhasil login (misalnya akun Sales atau Staff) dapat mengirim request POST langsung via cURL atau Postman ke `/erp/users/1/update` dengan membawa password baru. Sistem akan merespons `302 / 200 OK` dan mengubah password Superadmin (ID: 1) tanpa batasan.

D. Perbaikan Minimum yang Direkomendasikan:

- Pasang middleware `role:admin` pada seluruh rute users, roles, system-menus, dan system-configs di `routes/web.php`.
- Tambahkan validasi defensif `abort_if(!auth()->user()->isAdmin(), 403)` pada constructor atau awal method administratif.

E. Rencana Pengujian:

Feature test: Login sebagai user role `sales`, kirim POST ke `/erp/users`. Assert response `403 Forbidden`.

3 VERIFIKASI FILAMENT ADMIN PANEL

TEMUAN SEC-03: Akses Terbuka Tanpa Batas ke Filament Admin Panel

HIGH CONFIRMED

`Berkas: app/Models/User.php (L107-110), app/Providers/Filament/AdminPanelProvider.php (L30-74), app/Filament/Resources/*`

A. Jalur Eksekusi Lengkap:

1. Di `AdminPanelProvider.php`, panel dikonfigurasi dengan `->path('erp')` dan auth middleware `Authenticate::class`.
2. Middleware `Authenticate` memanggil method `canAccessPanel(Panel $panel)` pada model User.
3. Pada `app/Models/User.php` L107-110:

```
public function canAccessPanel(Panel $panel): bool
{
    return true; // Mengizinkan semua akun terotentikasi masuk ke Filament
}
```

4. Ketujuh Resource Filament (`ProductResource`, `CategoryResource`, `GalleryResource`, `PartnerResource`, dll.) tidak memiliki Model Policy dan tidak mendefinisikan method `canViewAny` atau `canDelete`.

B. Skenario Risiko:

> Karena rute Blade dan Filament berbagi path `/erp` dan cookie session yang sama, pengguna non-admin yang mengakses `/erp/products` atau `/erp/categories` mendapatkan akses penuh untuk menambah, mengedit, dan menghapus seluruh katalog produk dan konten CMS website publik.

C. Perbaikan Minimum yang Direkomendasikan:

Ubah `User::canAccessPanel()` agar mengembalikan `$this->isAdmin()`.

4 VERIFIKASI IDOR (INSECURE DIRECT OBJECT REFERENCES)

TEMUAN SEC-04: IDOR pada Mutasi Transaksi, PO Vendor, dan Catatan Keuangan

HIGH CONFIRMED

`Berkas: ErpController.php (L1752-1776, L1213-1220), ProcurementController.php (L743-775), FinanceController.php (L374-415)`

A. Analisis Pembuktian Berdasarkan Kategori Akses:

AKSI & ENDPOINT	TEMUAN KODE & MEKANISME	STATUS VERIFIKASI
Pembatalan Order `POST /erp/orders/{id}/cancel`	`$order = Order::findOrFail($id)` tanpa memeriksa `created_by` atau role admin. Order milik sales lain bahkan order berstatus `completed` dapat dibatalkan seketika.	CONFIRMED VULNERABLE
Edit Quotation `POST /erp/quotations/{id}/update`	Setiap sales dapat mengedit kuantitas, harga sewa, diskon, dan item penawaran milik sales lain hanya dengan mengetahui ID numerik penawaran.	CONFIRMED VULNERABLE
Batal PO Vendor `POST /procurement/orders/{id}/cancel`	Semua user dapat membatalkan Purchase Order vendor tanpa verifikasi role procurement / operational.	CONFIRMED VULNERABLE
Catat Pembayaran `POST /finance/payments`	Pengguna non-finance dapat menyisipkan pembayaran ke faktur mana pun melalui input `invoice_id`.	CONFIRMED VULNERABLE
Unduh PDF Transaksi `GET /erp/quotations/{id}/pdf`	ID sequential numerik (1, 2, 3...) memungkinkan scraping dokumen penawaran antar sales. Akses baca internal sebagian memang dibutuhkan bisnis.	POTENTIAL LEAK
Hapus Lead CRM `POST /erp/crm/leads/{id}/delete`	Memiliki validasi kepemilikan data: `if (!$isAdmin && $lead->sales_id != $currentUser->id) abort(403)`.	PROPERLY CONTROLLED

B. Perbaikan Minimum yang Direkomendasikan:

- Pada `cancelOrder` dan `updateQuotation`: tambahkan verifikasi `if (!$user->isAdmin() && $order->created_by !== $user->id) abort(403);` serta larang pembatalan jika order sudah selesai/terkirim.
- Pada modul Finance & Procurement: pasang middleware `role:admin,finance` dan `role:admin,procurement`.

5 MATRIKS RINGKASAN STATUS HASIL VERIFIKASI

ID	ASPEK KEAMANAN	STATUS	TINGKAT RISIKO	MEKANISME PENYEBAB INTI
SEC-01	Base64 Image Upload RCE	CONFIRMED	CRITICAL	Regex MIME mentah tanpa whitelist; folder public storage dapat mengeksekusi PHP di Apache/LiteSpeed cPanel.
SEC-02	Admin Route Authorization	CONFIRMED	CRITICAL	Middleware alias `'role'` tidak pernah dipasang di rute `/erp/users`, `roles`, `menus`, `configs`.
SEC-03	Filament Open Access	CONFIRMED	HIGH	`User::canAccessPanel()` me-return `true` mutlak; zero Model Policies pada Filament Resources.
SEC-04	IDOR Mutasi Transaksi & PO	CONFIRMED	HIGH	`cancelOrder` dan `updateQuotation` tidak memvalidasi `created_by` maupun role pengguna.
SEC-05	IDOR Document Read / Enum	POTENTIAL	MEDIUM	Auto-increment ID (1, 2, 3...) tanpa UUID; belum ada segmentasi kerahasiaan data penawaran antar sales.

ID	ASPEK KEAMANAN	STATUS	TINGKAT RISIKO	MEKANISME PENYEBAB INTI
SEC-06	CRM Lead Authorization	VERIFIED OK	LOW / OK	Sudah memiliki kontrol kepemilikan data `sales_id === auth()->id()` atau `isAdmin()`.

6 RENCANA REMEDIASI BERURUTAN (REMEDIATION PLAN)

PRIORITAS	TINDAKAN REMEDIASI TEKNIS	TARGET BERKAS
PRIORITAS 1 **Critical RCE**	Terapkan whitelist ekstensi (`jpg, jpeg, png, webp`) dan validasi MIME biner riil via `finfo_buffer` pada upload base64 quotation; tambahkan `.htaccess` proteksi di `storage/app/public/`.	`ErpController.php` `storage/app/public/.htaccess`
PRIORITAS 2 **Privilege Escalation**	Pasang middleware `role:admin` pada grup rute manajemen user, role, menu sistem, dan konfigurasi master perusahaan di `routes/web.php`.	`routes/web.php` `ErpController.php` `ConfigController.php`
PRIORITAS 3 **Filament Access**	Ubah `canAccessPanel()` di `app/Models/User.php` agar memverifikasi hak akses `$this->isAdmin()`.	`app/Models/User.php`
PRIORITAS 4 **IDOR Mutasi**	Tambahkan pengecekan kepemilikan `$order->created_by === auth()->id()` atau `isAdmin()` pada `cancelOrder` dan `updateQuotation`; pasang role check di PO dan Finance.	`ErpController.php` `ProcurementController.php` `FinanceController.php`

KONFIRMASI INTEGRITAS PEMERIKSAAN FASE 2A

Pemeriksaan mendalam ini dilakukan secara murni melalui inspeksi kode statis (*static code analysis*). Tidak ada berkas proyek yang dimodifikasi, tidak ada payload berbahaya yang dijalankan ke server, dan tidak ada operasi database yang dieksekusi.

Disiapkan oleh:

Senior Laravel Software Architect & Application Security Auditor

Tanggal Verifikasi:

19 Oktober 2026

Keylock ERP Security Verification Audit